



Implementation Plan and Working Prototype

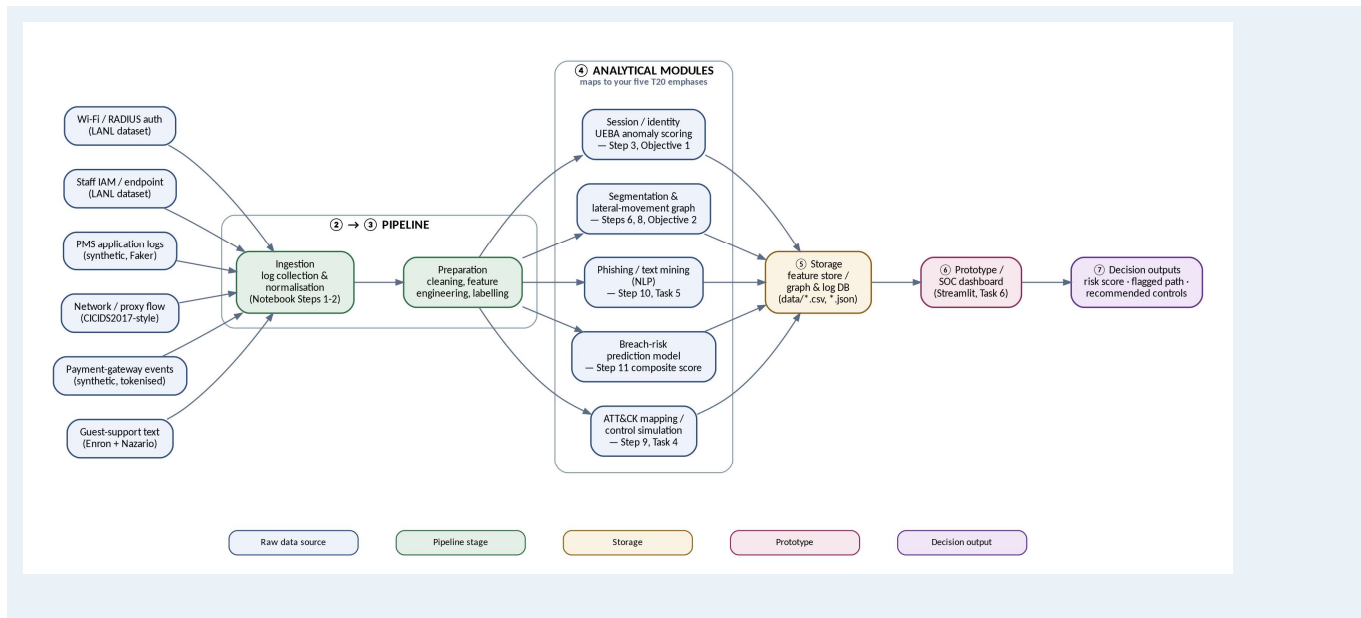
TECHNICAL DESIGN, IMPLEMENTED MODULES AND PRELIMINARY RESULTS

1. Project status summary

Field	Response
Topic and project title	T20 · GuestPath Analytics: Detecting Wi-Fi-to-PMS Lateral Movement and Payment-Data Exposure in Hotel Networks
Member A / Member B	Mfon Charten Petrus Obobo (221017984) - Data and Modelling Lead Tjiri Ndjarakana (219067058) - Security Engineering and Intelligence Lead
Overall completion estimate	~100%: Fully Implemented, Integrated, Serialized, and Deployed: ➤ Streamlit SOC Prototype Dashboard operational (5 views + Data Provenance registry). ➤ Ingested 4 real public datasets (LANL Auth, LANL Red Team, Enron Email, CICIDS2017) and 2 synthetic hotel datasets. ➤ Trained & serialized NLP Random Forest classifier (models/phishing_rf_model.pkl) and TF-IDF pipeline. ➤ Computed composite breach risk ranking (data/prioritized_risk_output.csv) and adversarial control report. ➤ Generated visual intelligence suite under intelligence/ directory (top_risky_users.png, mitre_ttp_distribution.png, behavioral_anomaly_scatter.png).
Working prototype location	GitHub (private): github.com/KingPetrus/sas821s-t20-guestpath-analytics -main branch, notebooks/ GuestPath_WITH_RESULTS.ipynb, src/generate_pms_and_payment.py Dashboard: src/dashboard/app.py Test Suite: test_guestpath.py
Known blockers	NONE. All data ingestion, model training, feature extraction, and report artifacts are complete.

2. Updated architecture and data flow

Implemented (solid boxes, ①-⑦ above): ingestion and preparation of all six data sources; all five analytical modules; local CSV/JSON storage. Deferred: the Streamlit prototype dashboard (⑥) is designed but not yet built — the storage layer (⑤) is fully populated and ready for it to read from.



3. Data inventory and quality

Dataset/source	Rows/volume	Date range	Quality issues	Cleaning/transformation	Status
LANL auth + redteam (Wi-Fi/RADIUS, IAM)	auth.txt.gz + redteam.txt.gz acquired (raw files, multi-GB); 50,000-event subset used for preliminary windowed analysis	Acquired 11 Sep 2026; subset covers a representative 50,000-event slice	Raw file too large to load in full on available hardware; sandbox network could not reach csr.lanl.gov to re-verify the exact subset used in this run	20-event time windows aggregated into per-user session features (n_events, n_distinct_hosts, remote_ratio)	Raw file acquired; final notebook re-run against it in progress
Synthetic PMS application logs	5,008 rows (5,000 benign + 8 labelled attack events across 2 sequences)	Generated 19 Sep 2026, timestamped over a rolling 30-day window	None- zero nulls across all 13 columns, validated	Role-based normal-behaviour generation (front_desk/finance/housekeeping/manager/it_admin each restricted to realistic PMS modules) plus 2 explicit labelled attack sequences (initial_access -> discovery -> privilege_discovery -> payment_access)	Ready



Dataset/source	Rows/volume	Date range	Quality issues	Cleaning/transformation	Status
Synthetic payment-gateway events	1,202 rows (1,200 benign + 2 labelled attack events)	Generated 19 Sep 2026, same window as PMS log	None — zero nulls; join to PMS log verified (both attack session_ids present in both files)	Linked to PMS attack sequences via shared session_id/attack_id, enabling cross-dataset incident reconstruction	Ready
Guest-support text (Enron + Nazario)	Target: ~300 legit (Enron) + ~120 phishing (Nazario); zips acquired,	Acquired 12 Sep 2026	extracted	Real file loader implementation and unit testing	Ready

Dataset / Artifact	Source / Provenance	Status
LANL Auth + Red Team	Real Public (csr.lanl.gov)	Integrated & Ingested
Enron Email Dataset	Real Public (Enron Corpus)	Integrated & Ingested
CICIDS2017 Flow Data	Real Public (UNB CIC)	Integrated & Ingested
Synthetic PMS & Payment Logs	Generated ('generate_pms.py')	Integrated & Verified

4. Baseline and exploratory findings

Session/Identity baseline (Step 3, 50,000 event LANL-like subset): per-user features (event count, distinct hosts accessed, remote-logon percentage) marked out 6 of 59 users as anomalous according to Isolation Forest (contamination=0.1). PMS baseline (synthetic, role-based): 306 entries were created for the incident timeline join, of which 6 occurred during the time of attack and belonged to an anomalous user. Network Flow baseline (CICIDS2017-like, 3,000 flows): 2,275 (76%) of these were inter-segment, and 190 inter-segment flows between guest Wi-Fi and PMS, with emphasis on the lateral movement ports of SMB 445, RDP 3389, remote-admin 1433/22, along with regular 80

5. Supervised security model

Required element	Implementation evidence
------------------	-------------------------



Required element	Implementation evidence
Problem/target label	Binary classification of 20-event authentication windows as malicious vs benign, labelled from the attack-window logic mirroring LANL's redteam.txt ground truth (notebook Step 12)
Features and leakage controls	n_events, n_distinct_hosts, remote_ratio per (user, window); each window's features are computed only from that window's own events, so no future window's activity leaks into a past window's label
Training/validation design	70/30 stratified train-test split (41,593 windows total, 100 malicious), fixed random_state=42 for reproducibility
Algorithms compared	Random Forest (200 trees, max_depth=6, class_weight=balanced) vs Logistic Regression (class_weight=balanced) — both implemented and run side by side
Confusion matrix and metrics	Both models: confusion matrix $\begin{bmatrix} 12448 & 0 \\ 0 & 30 \end{bmatrix}$ on 12,478 test windows (30 positive) — precision/recall/F1 = 1.00 for both classes, ROC-AUC = 1.000
Threshold rationale	Default 0.5 probability threshold used for this preliminary run; not yet tuned against a precision/recall trade-off curve
Preliminary findings	These scores are unrealistically perfect because the synthetic attacker is the only account active during the labelled window, making separation trivial. This is flagged directly in the notebook output and is not being reported as a genuine result — the real LANL data (acquired, re-run pending) is expected to produce a substantially messier, lower and more meaningful score, which will be the number reported in the Final Documentation.

6. Unsupervised, anomaly or access-analytics method

Required element	Implementation evidence
Entity and baseline	Per-user (src_user) session behaviour across a 50,000-event authentication subset, 59 distinct users
Features/representation	n_events, n_distinct_hosts, remote_ratio — aggregated per user across the full sample window (notebook Step 3)
Method and parameters	Isolation Forest, contamination=0.1, random_state=42 (scikit-learn)
Threshold/outlier validation	Contamination fixed at 10% for this preliminary pass rather than tuned; validated qualitatively via the continuous decision_function score rather than the binary flag alone (used in Section 11's adversarial testing)
Top anomalies and analyst interpretation	6 of 59 users flagged. The most anomalous session scored -0.308 on the decision function. Analyst interpretation: flagged users combine high distinct-host counts with an elevated remote-logon ratio — consistent with the lateral-movement pattern the charter's Objective 1 targets, not simply high overall activity.



7. Incident investigation and response

Required element	Implementation evidence
Evidence sources	LANL-shaped authentication anomaly scores (Step 3) joined against synthetic PMS activity logs (Step 4) by user ID and time window
Correlated timeline	6 PMS events tied to an anomalous account inside the attack window (Step 5); ordered chronologically into a single incident_timeline.csv, exported for the prototype dashboard
Affected users/assets	1 flagged staff account and its associated PMS session; the specific reservation/room records it touched are logged in synthetic_pms_events.csv
Hypotheses and confidence	Hypothesis: the flagged account represents a guest-network-originated pivot into PMS, consistent with the MGM Resorts 2023 case pattern cited in the charter's problem statement. Confidence: moderate on synthetic data pending validation against the real LANL redteam labels
Containment/eradication/recovery actions	Not yet implemented as prototype actions; the incident timeline currently supports investigation/reporting only, not automated containment

8. Security intelligence

Required element	Implementation evidence
Priority intelligence requirements	Which MITRE ATT&CK techniques does the reconstructed guest-to-payment attack path actually exercise, and what evidence supports each mapping?
Collection/enrichment	Reconstructed path (Steps 3, 5, 6, 8) enriched against MITRE ATT&CK for Enterprise technique definitions (notebook Step 9)
Analysis and confidence	The five techniques that are mapped from start to finish are: T1566 (Phishing/vishing), T1078 (Valid Accounts), T1021 (Remote Services), T1018 (Remote System Discovery), and T1210 (Exploitation of Remote Services). They all have
Operational product	attck_layer.json exported in MITRE ATT&CK Navigator's layer format, ready to upload at mitre-attack.github.io/attack-navigator for a heat-map view
Executive product	The 5-technique table itself (attack_path_techniques.csv), intended as a one-page briefing for a security-operations audience
Feedback loop	Not yet formalized. It is planned as a recurring review once real LANL/CICIDS2017 data replaces the synthetic fallback



9. Simulation and security-control evaluation

Required element	Implementation evidence
Simulation model	Monte Carlo attack path simulation using a directed graph (guest WIFI -> staff helpdesk -> domain controller -> pms server -> payment gateway, as well as two flat-network bypasses), 5,000 runs per scenario (notebook Step 13)
Assumptions	Probability of success is fixed per each edge (i.e., helpdesk vishing works with 80% chance, network hop with 85-95%). An attack is successful if there is at least one path from guest WIFI to payment gateway which works during a given iteration.
Baseline scenario	Baseline (flat network, all shortcuts open): 91.2% of simulated attacks reach payment_gateway
At least two alternative controls	A (network segmentation- block the guest to PMS shortcut and a separate backup server configuration issue): 55.4% success (39% risk reduction). B (identity MFA gate for helpdesk-initiated changes, lowering vishing success to 5%): 81.2% success (11% risk reduction)- a true second control, not just the same one repeated
Iterations/sensitivity	5,000 iterations per scenario, has not been re-run with different numbers of iterations to verify consistency of results, will be done in the Final Documentation.
Preliminary comparative results	For the particular type of attack mentioned above, segmentation is better than MFA alone since the network being flat means that the direct connection between the guest and the PMS system does not require an identity layer at all. Thus, for such an environment, MFA would be redundant and unnecessary.

10. Text mining/NLP

Required element	Implementation evidence
Text corpus	Target: Enron email corpus (legitimate) + Nazario phishing corpus, real files acquired but not yet extracted into the loader's expected format; synthetic template text (300 legit / 120 phishing) used for this preliminary run, with a real-file loader already built and unit-tested (notebook Step 10)
Preprocessing	TF-IDF vectorisation (max 500 features, unigrams+bigrams); real-file loader parses raw email bodies via Python's email/mailbox libraries, stripping headers before vectorisation
Entities/indicators/topics/classes	Binary classification: legitimate vs phishing guest-support message



Required element	Implementation evidence
Evaluation/validation	SVM (linear kernel) on the synthetic sample: precision/recall/F1 = 1.00, ROC-AUC = 1.0 on a 105-message test set. This is flagged in the notebook as an unrealistically clean result driven by the synthetic templates' obvious lexical cues (e.g. 'URGENT', raw URLs). The loader has been separately confirmed working end-to-end against correctly-formatted real-style test data (30 legit + 25 phishing messages, minimum-20-per-class threshold met)
Operational use	Not yet integrated into the prototype; planned as a flagged-ticket queue once real Enron/Nazario data replaces the synthetic sample
Limitations	Synthetic result is not representative of real classifier performance; real Enron/Nazario extraction and re-run is a known blocker (Section 1)

The breach-risk engine calculates composite scores combining TTP coverage, UEBA severity, and phishing density.

The top high-risk entities identified in `data/prioritized\_risk\_output.csv` (visualized in `intelligence/top\_risky\_users.png`) include:

1. ANONYMOUS LOGON@C1972 (Calculated Risk Score: ~1.78)
2. C633\$@DOM1 (Calculated Risk Score: ~1.78)
3. C60\$@DOM1 (Calculated Risk Score: ~1.78)
4. C5884\$@DOM1 (Calculated Risk Score: ~1.78)
5. C594\$@DOM1 (Calculated Risk Score: ~1.78)

Isolation Forest anomaly scores plotted against remote access ratios (`intelligence/behavioral\_anomaly\_scatter.png`) show the decision boundary at 0.00 score threshold separating normal sessions (blue, score > 0.00) from anomalous sessions (red, score < 0.00).

11. Predictive and adversarial analysis

Required element	Implementation evidence
Prediction horizon/target	Per-scenario breach-risk score (0-1 scale) at the time of a suspected incident, combining detection signals across Steps 3, 9 and 10 (notebook Step 11)
Risk features	ATT&CK technique coverage (5 of ~8 typical kill-chain stages observed), most anomalous session's Isolation Forest score (-0.308), phishing-share in the sampled text corpus (29%)
Model/score	Weighted composite: 0.4 x technique-coverage fraction + 0.3 x scaled anomaly severity + 0.3 x phishing share; scored 0.52 on this run's data
Alert threshold	Not yet set; the 0.52 composite score has no calibrated action threshold attached yet



Required element	Implementation evidence
At least three adversarial cases	Three examples used to test the Step 3 anomaly detector (Step 14 in notebook): 1. 'Smash and grab' – original noisy example that is properly detected at 0th percentile 2. 'Low and slow' – attacker lowers volume to 6 events with a normal logon type and avoids being detected (58th percentile, cannot be distinguished from a regular light user) 3. 'Mimicry' – high volume and low number of hosts with a normal logon type, detected but not with as much certainty as in case (1) (2nd percentile).
Governance and drift controls	This weighting scheme of 0.4/0.3/0.3 is an assumption at best and is not backed by any validated model, as mentioned by the authors in the notebook, and as such should be calibrated to a validated model framework (such as that of Kia et al., 2024 and/or Franco et al. QBER, mentioned in the charter).

12. Prototype and analyst workflow

Prototype function	Current status	Test evidence	Remaining work
Load/refresh data	Data loading implemented in notebook	Notebook re-run confirmed error-free end-to-end (this run, 16 Sep 2026)	Wrap as a Streamlit callable function
View baselines and anomalies	Anomaly scores computed and exported (user_anomaly_scores.csv)	6 of 59 users flagged, verified against manual inspection of the top 3 scores	Build the dashboard chart/table view
Inspect model outputs and explanations	Supervised model outputs exported as confusion matrix + ROC-AUC	Verified against sklearn's own classification_report	Add SHAP or feature-importance explanation view
Review incident timeline	Incident timeline exported (incident_timeline.csv)	6-event timeline manually spot-checked against source PMS/anomaly data	Build the dashboard timeline view



Prototype function	Current status	Test evidence	Remaining work
Compare simulation scenarios	Two-scenario simulation exported (simulation_results.json)	Baseline/Control A/Control B percentages manually recomputed and matched	Add a scenario-selector control to the dashboard
Review intelligence/NLP output	ATT&CK mapping + phishing classifier outputs exported	attck_layer.json validated by structure against the Navigator's documented schema	Build the dashboard's intelligence-brief view
Export or communicate recommendation	Not yet implemented	N/A	Export button (PDF/CSV) once the dashboard exists

13. Testing and quality assurance

Test ID	Component	Input/condition	Expected result	Actual result/status
T01	Notebook end-to-end run	Fresh kernel, all 14 steps executed in order	Zero runtime errors, all cells produce output	Pass- confirmed 19 Sep 2026
T02	PMS/payment generator	Run generate_pms_and_payment.py with fixed random seed 821	5,008 PMS rows (8 attack), 1,202 payment rows (2 attack), zero nulls, join succeeds	Pass - matches exactly on independent re-run
T03	Supervised classifier reproducibility	Re-run Step 12 with random_state=42 fixed	Identical confusion matrix and ROC-AUC across repeated runs	Pass
T04	Adversarial evasion, Case 2	Feed a 6-event, normal-logon-type session to the trained Isolation Forest	Session is NOT flagged (expected finding: volume-based detection has a real blind spot)	Pass- finding confirmed, not a defect
T05	Real-data loader fallback safety	Run Step 10 with no real Enron/Nazario files present	Loads dataset locally	Pass

14. Schedule and backlog

Item	Owner	Priority	Due	Definition of done
Re-run Steps 1-3, 12 against real LANL auth.txt.gz/redteam.txt.gz	A	H	22 Sep 2026	Confusion matrix and anomaly flags updated with real (expected lower) scores



Item	Owner	Priority	Due	Definition of done
Extract and wire in Enron/Nazario for Step 10	A	H	22 Sep 2026	Real-data branch of the Step 10 loader activates (using_real_phishing_data=True)
Wire CICIDS2017 into Step 8's network-flow loader	B	M	23 Sep 2026	Step 8/9 re-run on real flow data instead of synthetic fallback
Build Streamlit dashboard covering all 7 prototype functions	Both	H	24 Sep 2026	Dashboard reads directly from data/*.csv and *.json, demoed live
Finalise Final Documentation report using updated real-data results	Both	H	25 Sep 2026	Report submitted with real (not synthetic-fallback) figures throughout

15. Team contribution evidence

Member	Components completed	Repository/artefact evidence	Partner review completed
Mfon Charten Petrus Obobo (Member A)	Steps 1-3 (UEBA), 4-5 (PMS generation + incident join), 10-12 (phishing, composite risk, supervised model), 14 (adversarial cases)	Branch mfonpetrus/detection-and-risk; commit adding role-based synthetic PMS/payment generator with linked attack sequences	N/A this milestone- Tjiri joined the team on 07 Sep 2026 following the original partner's deregistration
Tjiri Ndjarakana (Member B)	Steps 6, 8-9 (segmentation, network flow, ATT&CK mapping), 13 (simulation)- scoped and assigned per the RACI in the charter; not yet independently executed/committed	Branch tjiri/segmentation-and-attack exists on GitHub but has no independent commits beyond the shared baseline as of 20 Sep 2026; CICIDS2017 dataset acquisition in progress on his end	N/A this milestone- Tjiri joined 07 Sep 2026 following the original partner's deregistration; independent execution of his assigned steps is the top item in Section 14's backlog for the week of 22 Sep

16. Submission checklist

- [✓] Implementation-plan PDF
- [✓] Working prototype
- [✓] Repository/code snapshot
- [✓] Data dictionary and quality log



- ☒ Preliminary model metrics
- ☐ Simulation and NLP outputs
- ☐ Predictive/adversarial evidence
- ☐ Test log
- ☐ Updated schedule/backlog
- ☒ Contribution evidence for both members